

Password Hashing Cheat Sheet

Do

- Hash passwords with bcrypt, scrypt, or Argon2 — never store plaintext.
- Let the library generate and store a unique salt per user automatically.
- Use a cost factor that takes roughly 200–500ms to compute on your server.

Don't

- Don't use fast general-purpose hashes like MD5 or SHA-256 alone for passwords.
- Don't write your own hashing scheme.
- Don't log plaintext passwords anywhere, even temporarily for debugging.

If a breach happens anyway

- Force a password reset for all affected accounts.
- Check whether your hashing cost factor was strong enough to slow down cracking attempts.
- Notify affected users promptly and plainly — don't downplay it.